

② L2-09

O artigo descreve as atividades que devem ser integradas ao ciclo de vida de desenvolvimento (SDLC) para produzir software seguro. A ideia central é que segurança não pode ser "colada" no fim do projeto: precisa estar embutida em todas as fases, do planejamento à operação.

Atividades essenciais

- Treinamento e conscientização - capacitar a equipe em codificação segura e nas ameaças comuns;
- Requisitos de segurança? definidos junto aos funcionários, com classificação dos dados;
- Modelagem de ameaças (Threat modeling) - no ~~design~~ design, identificar ameaças antes de codificar (Ex: STRIDE);
- Design e arquitetura seguros - menor privilégio, defesa em profundidade, segurança por padrão;
- Codificação segura - validar entradas, Prepared Statement, escapar saídas, rotas seguras no código;
- Revisão do código e análise estática (SAST);
- Testes de segurança - DAST, SCA (dependências) e pentest;
- Gestão de configurações e vulnerabilidades - patches e resposta a incidentes (CUEg)

Essas atividades são organizadas por frameworks de maturidade como Microsoft SDL, OWASP SAMM, BSIMM e NIST SSDF. O SSDF, por exemplo, agrupa tudo em quatro áreas: preparar a organização, proteger o software, produzir software sem prejuízo e responder a ~~soft~~ vulnerabilidades.

Conclusão: adotar essas atividades continuamente reduz vulnerabilidades, diminui custos (shift-left) e incorpora a segurança.

do produto. Seguramos é responsabilidades de todos o time, não
de uma etapa isolada.